PURPOSE CAPITAL
Guiding Capital with Purpose

POLITIQUE · SYSTÈMES D'INFORMATION

# Politique de sécurité des systèmes d'information

Version **0.9** PROJET

| | |
|---|---|
| Propriétaire | Directeur Général |
| Prochaine revue | 12 mois après adoption |
| Confidentialité | Interne |

PROJET

**Purpose Capital S.A.**
Rue Joseph Essono Balla, Elig-Essono, Yaoundé (Cameroun)

Édité le 12 novembre 2026

# Fiche de maîtrise documentaire

| | | | |
|---|---|---|---|
| **Version** | 0.9 — Projet | | |
| **Titre** | Politique de sécurité des systèmes d'information | | |
| **Type · domaine** | Politique · Systèmes d'information | **Confidentialité** | Interne |
| **Propriétaire** | Directeur Général | | |
| **Diffusion** | Aucune lecture obligatoire désignée | | |
| **Date d'effet** | À l'adoption | **Prochaine revue** | 12 mois après adoption |

## CIRCUIT D'APPROBATION

| Étape | Fonction | Visa électronique | Signature manuscrite |
|---|---|---|---|
| Rédaction | RCCI | En attente | Date et signature |
| Approbation | Directeur Général | En attente | Date et signature |
| Adoption par le Conseil d'Administration | Président du Conseil d'Administration | En attente | Date et signature |

## HISTORIQUE DES RÉVISIONS

| Version | Date | Objet | Par |
|---|---|---|---|
| 0.9 | 20 octobre 2026 | Projet initial soumis au Conseil d'Administration | RCCI |
| 0.9 | 20 octobre 2026 | Mise en forme : dates d'adoption et signatures reportées dans la fiche de maîtrise documentaire | RCCI |

## TEXTES DE RÉFÉRENCE

| | |
|---|---|
| Loi n° 2024/017 du 23 décembre 2024 relative à la protection des données à caractère personnel au Cameroun<br>Présentation · droitmediasfinance.com | Sécurité des données personnelles, obligations à l'égard des sous-traitants, notification des violations |
| Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité au Cameroun<br>Présentation · dig.watch | Cadre camerounais de la cybersécurité, atteintes aux systèmes d'information, rôle de l'ANTIC |
| Règlement général de la COSUMAF du 23 mai 2023<br>Texte officiel · cosumaf.org | Conservation et accès de la COSUMAF aux documents et enregistrements |
| Normes ISO/IEC 27001 et 27002 (2022) — Sécurité de l'information | Norme internationale : système de management de la sécurité de l'information et mesures de sécurité (ISO 27002) |
| NIST — Cybersecurity Framework 2.0 (2024)<br>Texte officiel · nvlpubs.nist.gov | Bonne pratique internationale : six fonctions (gouverner, identifier, protéger, détecter, répondre, rétablir) |
| ANSSI — Guide d'hygiène informatique<br>Texte officiel · cyber.gouv.fr | Juridiction comparable : mesures d'hygiène informatique pour les petites structures |
| Comité de Bâle — Principes de saine gestion du risque opérationnel (révision 2021)<br>Texte officiel · bis.org | Bonne pratique internationale : sécurité de l'information et résilience opérationnelle |

PROJET

# Sommaire


## I. Dispositions générales

Article 1 — Objet
Article 2 — Pourquoi cette politique compte
Article 3 — Champ d'application
Article 4 — Définitions

## II. Organisation

Article 5 — Rôles
Article 6 — Principes

## III. Les informations

Article 7 — Classification
Article 8 — Où sont les informations

## IV. Accès et identités

Article 9 — Comptes nominatifs et authentification
Article 10 — Comptes à privilèges et compte d'urgence
Article 11 — Arrivées, changements, départs
Article 12 — Revue des accès

## V. Postes, messagerie et services en ligne

Article 13 — Postes de travail et téléphones
Article 14 — Messagerie
Article 15 — Services en ligne et prestataires
Article 16 — Travail à distance

## VI. Données, journaux et changements

Article 17 — Sauvegardes
Article 18 — Développement et changements du Guichet
Article 19 — Journalisation

## VII. Incidents

Article 20 — Déclaration et traitement
Article 21 — Retour d'expérience

## VIII. Sensibilisation, contrôle et dispositions finales

Article 22 — Sensibilisation
Article 23 — Contrôle
Article 24 — Manquements
Article 25 — Révision et entrée en vigueur

## Annexes

Annexe « Charte d'utilisation » — Charte d'utilisation des outils numériques
Annexe « Matrice des accès » — Matrice des accès et revue semestrielle
Annexe « Arrivées et départs » — Liste d'arrivée et de départ d'un collaborateur
Annexe « Déclaration d'incident de sécurité » — Fiche de déclaration d'un incident de sécurité
Annexe « Mesures minimales » — Mesures minimales par outil


PROJET

# Titre I — Dispositions générales

### Article 1 — Objet

La présente politique fixe les règles qui protègent les informations de Purpose Capital S.A. (la « Société ») et de ses clients contre la perte, le vol, la divulgation et l'indisponibilité. Elle dit qui est responsable, ce que chacun doit faire, et ce que la Société attend de ses prestataires.

Elle remplace les exigences minimales de l'article 19 de la Politique de gestion des risques et s'applique avec le Plan de continuité d'activité et la Politique d'externalisation.

### Article 2 — Pourquoi cette politique compte

Une société de bourse détient ce que ses clients ont de plus sensible : leur identité, leurs comptes, leurs avoirs, leurs ordres. Une messagerie piratée suffit à détourner un virement ; un ordinateur perdu, à exposer des centaines de dossiers. La loi camerounaise sur la protection des données personnelles oblige la Société à protéger ces données et à signaler leur violation.

La Société est petite, ses outils sont presque tous en ligne et son informatique est confiée à un prestataire. La sécurité repose donc surtout sur quelques règles simples, appliquées par tous, et sur la maîtrise des comptes d'accès.

### Article 3 — Champ d'application

La politique s'applique :

- à tous les collaborateurs, dirigeants, administrateurs, stagiaires et prestataires qui utilisent les outils de la Société ;
- à tous les outils : postes de travail, téléphones professionnels, messagerie et bureautique en ligne, Guichet, site internet, banque en ligne, accès aux systèmes de la BVMAC et du Dépositaire central ;
- quel que soit le lieu de travail : bureau, domicile ou déplacement.

### Article 4 — Définitions

- **Système d'information** : l'ensemble des matériels, logiciels, services en ligne et données utilisés par la Société.
- **Compte à privilèges** : compte qui permet d'administrer un service, de créer des utilisateurs ou de modifier des réglages de sécurité.
- **Authentification à plusieurs facteurs** : connexion qui exige, en plus du mot de passe, un second élément (code d'une application, clef d'accès).
- **Incident de sécurité** : événement qui compromet ou peut compromettre la confidentialité, l'intégrité ou la disponibilité d'une information ou d'un outil.

PROJET

# Titre II — Organisation

## Article 5 — Rôles

| Fonction | Responsabilités |
|---|---|
| Conseil d'Administration | Approuve la politique ; reçoit chaque année le bilan de la sécurité et des incidents |
| Directeur Général | Responsable de la sécurité du système d'information ; alloue les moyens ; détient avec le Président du Conseil l'accès au compte d'urgence |
| Référent informatique interne | Collaborateur désigné par le Directeur Général : tient la matrice des accès, suit le prestataire, organise les arrivées et départs, premier interlocuteur en cas d'incident |
| Prestataire informatique | Administre les outils selon son contrat et la présente politique ; applique les mises à jour ; signale les incidents dans les 24 heures |
| RCCI | Contrôle l'application de la politique ; tient le registre des incidents ; vérifie la protection des données personnelles |
| Collaborateurs | Appliquent la charte d'utilisation de l'annexe « Charte d'utilisation » ; signalent sans délai tout incident ou doute |

## Article 6 — Principes

1. **Le besoin d'en connaître** : chacun n'accède qu'aux informations nécessaires à son travail.
2. **Le moindre privilège** : les droits d'administration sont réservés à ceux qui en ont besoin, et utilisés depuis des comptes distincts.
3. **La Société garde la main** : elle détient elle-même ses comptes principaux et son compte d'urgence, et ne dépend jamais d'un seul prestataire ou d'une seule personne pour accéder à ses données.
4. **La simplicité** : une règle comprise et appliquée vaut mieux qu'une règle parfaite ignorée.

PROJET

# Titre III — Les informations

### Article 7 — Classification

| Niveau | Exemples | Règles |
|---|---|---|
| Public | Site internet, brochure, communiqués | Diffusion libre après validation |
| Interne | Procédures, notes internes, planning | Collaborateurs et prestataires sous contrat de confidentialité |
| Confidentiel | Dossiers clients, ordres, positions, données personnelles, comptabilité, rapports de contrôle | Accès selon la matrice de l'annexe « Matrice des accès » ; jamais par messagerie personnelle ; chiffrement pour tout envoi externe |
| Secret | Informations privilégiées, déclarations de soupçon, mots de passe et clefs | Accès nominatif et tracé ; jamais copié hors des outils prévus |

Un document qui n'est pas marqué est traité comme **interne**. Un document qui contient des données de clients est toujours **confidentiel**.

### Article 8 — Où sont les informations

Les informations de la Société sont enregistrées dans ses outils : l'espace de stockage en ligne de la Société, la messagerie professionnelle, le Guichet. Elles ne sont pas conservées durablement sur le disque d'un poste, sur une clé USB personnelle ou dans un service en ligne personnel. Les documents papier confidentiels sont rangés sous clé.

PROJET

# Titre IV — Accès et identités

### Article 9 — Comptes nominatifs et authentification

- Chaque personne a un **compte nominatif** ; les comptes partagés sont interdits, sauf boîte de réception collective sans droit d'administration.
- **L'authentification à plusieurs facteurs est obligatoire** pour tous les comptes : messagerie et bureautique, Guichet (desk et responsables), hébergeurs, banque en ligne, registraire du nom de domaine, accès aux systèmes de marché.
- Le mot de passe compte au moins 12 caractères, est propre à chaque service et conservé dans le coffre-fort numérique de la Société. Il n'est jamais communiqué, même au prestataire ou à un dirigeant.

### Article 10 — Comptes à privilèges et compte d'urgence

- Les droits d'administration sont attribués à des comptes distincts des comptes de travail quotidiens, au plus à deux personnes par service en plus du prestataire.
- La Société détient un **compte d'urgence** d'administration de sa messagerie, sans licence, rattaché au domaine technique du fournisseur, protégé par une clef d'accès physique, et dont l'usage déclenche une alerte. Ses éléments d'accès sont conservés sous scellé, sous la responsabilité conjointe du Directeur Général et du Président du Conseil d'Administration.
- Toute utilisation d'un compte d'urgence est consignée et justifiée auprès du RCCI.

### Article 11 — Arrivées, changements, départs

À chaque arrivée, changement de fonction ou départ, le référent informatique applique la liste de l'annexe « Arrivées et départs ». Au départ d'un collaborateur, ses accès sont **coupés le jour même**, son matériel restitué, et les mots de passe et clefs qu'il connaissait renouvelés. Les accès d'un prestataire sont coupés à la fin de sa mission.

### Article 12 — Revue des accès

Tous les six mois, le référent informatique et le RCCI revoient la matrice des accès de l'annexe « Matrice des accès » : chaque compte doit correspondre à une personne présente et à un besoin. Les comptes inutiles sont supprimés. La revue est datée et signée.

PROJET

# Titre V — Postes, messagerie et services en ligne

### Article 13 — Postes de travail et téléphones

- Seuls les **ordinateurs portables fournis par la Société** traitent des données confidentielles. Ils sont chiffrés, protégés par un mot de passe ou un code et verrouillés automatiquement après cinq minutes d'inactivité.
- Le système et les logiciels sont **mis à jour** automatiquement ; une mise à jour de sécurité est installée dans les sept jours.
- L'antivirus intégré au système est actif et à jour. L'installation de logiciels est réservée au prestataire ou au référent informatique.
- Le téléphone professionnel est protégé par un code et peut être effacé à distance.
- Un poste perdu ou volé est signalé immédiatement : il est bloqué et effacé à distance.

### Article 14 — Messagerie

La messagerie est la porte d'entrée la plus fréquente des fraudes. La Société :

- publie les enregistrements d'authentification de son domaine (SPF, DKIM, DMARC) pour empêcher qu'on envoie des messages en son nom ;
- filtre les messages entrants et signale les messages venant de l'extérieur ;
- interdit le transfert automatique de la messagerie professionnelle vers une adresse personnelle.

Les collaborateurs **ne donnent suite à aucune demande de paiement, de changement de coordonnées bancaires ou de mot de passe reçue par messagerie** sans l'avoir confirmée par un autre canal, au numéro déjà connu (Procédure d'entrée en relation, article 17).

### Article 15 — Services en ligne et prestataires

Chaque service en ligne utilisé par la Société (messagerie et bureautique, hébergement du site et du Guichet, base de données, envoi de messages, référentiel documentaire) est inscrit au registre des externalisations et suit la Politique d'externalisation, en particulier :

- la Société est titulaire de ses comptes et de ses données, et en détient les accès principaux ;
- la localisation des données est connue, et tout transfert de données personnelles hors du Cameroun respecte la loi ;
- les paramètres de sécurité disponibles sont activés : authentification à plusieurs facteurs, alertes de connexion, journalisation.

Les clefs techniques (clefs d'API, secrets d'application) sont conservées dans les variables protégées de l'hébergeur, jamais dans le code, dans un message ou dans un document. Chaque fournisseur d'API fait l'objet d'un plafond de dépense et d'une alerte de budget. Une clef est renouvelée sans attendre au départ d'une personne qui y avait accès ou si elle a pu être exposée, et au moins une fois par an.

### Article 16 — Travail à distance

Le travail à distance suit les règles du Plan de continuité d'activité (article 17). En particulier : pas de réseau Wi-Fi public, préférer la connexion partagée du téléphone ; écran hors de vue des tiers ; aucun document confidentiel imprimé hors du bureau sans nécessité.

PROJET

# Titre VI — Données, journaux et changements

### Article 17 — Sauvegardes

Les données importantes existent en **trois copies, sur deux supports différents, dont une hors ligne ou chez un autre fournisseur que le principal**. Les sauvegardes sont quotidiennes. La restauration est testée chaque trimestre, conformément au Plan de continuité d'activité.

### Article 18 — Développement et changements du Guichet

Le Guichet, développé et exploité par la Société, suit les règles suivantes :

- toute modification passe par une branche distincte, une prévisualisation vérifiée par un responsable, puis une fusion relue avant déploiement en production ;
- les modifications de la base de données sont jouées et vérifiées avant le déploiement du code qui les utilise ;
- les données réelles des clients ne sont pas utilisées hors de l'environnement de production ;
- un retour à la version précédente est possible à tout moment, et la procédure en est écrite ;
- l'accès au desk exige le second facteur ; aucun utilisateur ne peut approuver sa propre proposition ni modifier son propre niveau d'accès.

### Article 19 — Journalisation

Les connexions, les actions d'administration et les opérations sensibles sont journalisées : journaux de connexion de la messagerie, journal d'audit chaîné du Guichet, historiques des hébergeurs. Les journaux sont conservés au moins un an, et dix ans pour ceux qui prouvent un ordre ou une opération d'un client. Le référent informatique consulte les alertes de connexion chaque semaine. Une rupture de la chaîne d'audit du Guichet est un incident de sécurité.

PROJET

# Titre VII — Incidents

### Article 20 — Déclaration et traitement

Tout collaborateur qui constate ou soupçonne un incident (message suspect cliqué, poste perdu, compte utilisé par un tiers, demande de paiement frauduleuse, fuite d'un document) le **signale immédiatement** au référent informatique et au RCCI, sans chercher à le régler seul ni à en effacer les traces. L'incident est déclaré dans les 24 heures sur la fiche de l'annexe « Déclaration d'incident de sécurité ».

Le traitement suit l'article 12 du Plan de continuité d'activité : isoler, bloquer, prévenir les fraudes, restaurer, informer. Un incident qui touche des données de clients est porté à la connaissance du Directeur Général ; il décide de l'information des clients concernés, de l'autorité de protection des données dans les conditions prévues par la loi et, si l'incident est significatif, de la COSUMAF.

### Article 21 — Retour d'expérience

Tout incident significatif fait l'objet d'une analyse de cause et d'un plan d'action suivis par le RCCI selon la Charte du contrôle interne et de la conformité.

PROJET

# Titre VIII — Sensibilisation, contrôle et dispositions finales

### Article 22 — Sensibilisation

Chaque collaborateur signe la charte d'utilisation de l'annexe « Charte d'utilisation » à son arrivée. Une sensibilisation aux fraudes et à l'hameçonnage est faite chaque année et à chaque nouvelle forme de fraude observée ; elle peut comprendre un exercice d'hameçonnage simulé.

### Article 23 — Contrôle

Le RCCI vérifie l'application de la politique selon le plan de contrôle annuel, notamment la revue semestrielle des accès, les tests de restauration, les mesures minimales de l'annexe « Mesures minimales » et le suivi des incidents. La revue indépendante annuelle porte aussi sur la sécurité des systèmes d'information.

### Article 24 — Manquements

Le non-respect de la présente politique peut entraîner des sanctions disciplinaires, selon le Code de bonne conduite et le règlement intérieur, sans préjudice des poursuites prévues par la loi en cas d'atteinte à un système d'information.

### Article 25 — Révision et entrée en vigueur

La politique est revue au moins une fois par an et après tout incident significatif ou changement important d'outil. Toute modification est approuvée par le Conseil d'Administration.

La présente politique entre en vigueur à la date de son adoption par le Conseil d'Administration, indiquée dans la fiche de maîtrise documentaire.

PROJET

ANNEXE « CHARTE D'UTILISATION » · POLITIQUE DE SÉCURITÉ DES SYSTÈMES D'INFORMATION · ENGAGEMENT

# Charte d'utilisation des outils numériques

Version 0.9
Interne

**Renseigné par** Chaque collaborateur, stagiaire ou prestataire ayant un compte

**Fréquence** À l'arrivée et à chaque révision de la charte **Conservé par** Dossier du collaborateur ; copie au RCCI

En utilisant les outils de Purpose Capital S.A., je m'engage à respecter les règles suivantes.

### Mes accès

1. J'utilise uniquement mon compte nominatif, avec l'authentification à plusieurs facteurs. Je ne prête jamais mes accès et je ne communique jamais un mot de passe ou un code, à personne, même à un dirigeant ou au prestataire informatique.
2. J'utilise un mot de passe différent pour chaque service, conservé dans le coffre-fort numérique de la Société.

**Mon matériel** 3. Je traite les données des clients uniquement sur le matériel fourni par la Société. Je verrouille mon poste dès que je le quitte. 4. Je n'installe aucun logiciel et je ne branche aucune clé USB inconnue. 5. Je signale immédiatement la perte ou le vol de mon ordinateur ou de mon téléphone.

**Les informations** 6. J'enregistre mes documents dans les espaces de la Société, jamais dans un service personnel ou par transfert vers ma messagerie personnelle. 7. Je n'envoie de données de clients qu'aux personnes qui en ont besoin, par les canaux de la Société. Je ne reçois ni ne transmets d'ordres par une messagerie personnelle. 8. Je ne parle pas d'informations confidentielles dans un lieu public et je garde mon écran hors de vue des tiers.

**Les fraudes** 9. Je ne donne suite à aucune demande de paiement, de changement de coordonnées bancaires ou de mot de passe reçue par messagerie sans l'avoir confirmée par un autre canal, au numéro déjà connu. 10. En cas de doute sur un message, je ne clique pas et je le signale au référent informatique.

**Les incidents** 11. Je signale immédiatement tout incident ou doute au référent informatique et au RCCI, sans chercher à le régler seul.

**Le contrôle** 12. Je sais que l'usage des outils de la Société est journalisé, dans le respect de la loi, et que tout manquement peut entraîner des sanctions disciplinaires.

| NOM ET FONCTION | DATE | SIGNATURE, PRÉCÉDÉE DE « LU ET APPROUVÉ » |
|---|---|---|
| | | |

PROJET

ANNEXE « MATRICE DES ACCÈS » · POLITIQUE DE SÉCURITÉ DES SYSTÈMES D'INFORMATION · REGISTRE

# Matrice des accès et revue semestrielle

Version 0.9
Interne

**Renseigné par** Référent informatique ; revue avec le RCCI **Fréquence** Mise à jour à chaque arrivée, changement ou départ ; revue tous les six mois **Conservé par** RCCI · dix ans

Une ligne par compte. Niveau : U utilisateur, A administrateur, U+ utilisateur avec droits d'approbation. MFA : authentification à plusieurs facteurs active. Lignes d'exemple à compléter.

| Service | Titulaire du compte (fonction) | Niveau | MFA | Ouvert le | Justification du besoin | Revue 1 (date, maintenu ?) | Revue 2 (date, maintenu ?) | Fermé le |
|---|---|---|---|---|---|---|---|---|
| Messagerie et bureautique | Directeur Général | A | ☐ | | Administration du tenant | | | |
| Messagerie et bureautique | Compte d'urgence | A | ☐ clef physique | | Accès de secours, sous scellé | | | |
| Messagerie et bureautique | Prestataire informatique | A | ☐ | | Contrat d'infogérance | | | |
| Guichet (desk) | Responsable | U+ | ☐ | | Approbations, gestion de l'équipe | | | |
| Guichet (desk) | Opérateur desk | U | ☐ | | Traitement des dossiers et des ordres | | | |
| Hébergeur du Guichet et base de données | | A | ☐ | | Exploitation du Guichet | | | |
| Dépôt de code | | A | ☐ | | Développement du Guichet | | | |
| Hébergeur du site et DNS, registraire du domaine | | A | ☐ | | Site internet et domaine | | | |
| Banque en ligne | | U | ☐ | | Paiements, double signature | | | |
| Systèmes BVMAC et Dépositaire central | | U | ☐ | | Négociation et règlement | | | |
| Coffre-fort de mots de passe | | A | ☐ | | Gestion des secrets | | | |

REVUE DU · COMPTES SUPPRIMÉS

RÉFÉRENT INFORMATIQUE

RCCI

PROJET

ANNEXE « ARRIVÉES ET DÉPARTS » · POLITIQUE DE SÉCURITÉ DES SYSTÈMES D'INFORMATION · LISTE DE CONTRÔLE

# Liste d'arrivée et de départ d'un collaborateur

Version 0.9
Interne

**Renseigné par** Référent informatique

**Fréquence** À chaque arrivée, changement de fonction ou départ, y compris d'un stagiaire ou d'un prestataire

**Conservé par** Dossier du collaborateur ; copie au RCCI

NOM ET FONCTION _____

☐ ARRIVÉE ☐ CHANGEMENT ☐ DÉPART _____

DATE D'EFFET _____

| ✓ | Arrivée ou changement | ✓ | Départ (le jour même) |
|---|---|---|---|
| ☐ | Charte d'utilisation (Annexe « Charte d'utilisation ») signée | ☐ | Comptes bloqués : messagerie, Guichet, hébergeurs, banque, systèmes de marché |
| ☐ | Compte nominatif créé, authentification à plusieurs facteurs activée | ☐ | Sessions ouvertes fermées sur tous les appareils |
| ☐ | Droits attribués selon la fonction, inscrits à la matrice (Annexe « Matrice des accès ») | ☐ | Ordinateur, téléphone, clefs d'accès et badges restitués |
| ☐ | Ordinateur portable chiffré et téléphone remis, inventaire signé | ☐ | Boîte de messagerie transférée au responsable, réponse automatique posée |
| ☐ | Accès au coffre-fort de mots de passe, limité aux secrets nécessaires | ☐ | Mots de passe partagés et clefs techniques connus renouvelés |
| ☐ | Sensibilisation aux fraudes et à la présente politique | ☐ | Habilitations bancaires et de marché retirées auprès des tiers |
| ☐ | Habilitations bancaires ou de marché demandées si nécessaire | ☐ | Matrice des accès mise à jour ; licence libérée |
| ☐ | Changement : anciens droits retirés | ☐ | Rappel écrit de l'obligation de confidentialité |

RÉFÉRENT INFORMATIQUE · DATE _____

COLLABORATEUR · SIGNATURE _____

VISA DU RCCI _____

PROJET

ANNEXE « DÉCLARATION D'INCIDENT DE SÉCURITÉ » · POLITIQUE DE SÉCURITÉ DES SYSTÈMES D'INFORMATION · FORMULAIRE

# Fiche de déclaration d'un incident de sécurité

Version 0.9
Interne

**Renseigné par** Tout collaborateur, puis référent informatique et RCCI **Fréquence** Dans les 24 heures suivant la découverte

**Conservé par** RCCI (registre des incidents) · dix ans

Complète la fiche d'incident de la Politique de gestion des risques (Annexe « Déclaration d'incident de sécurité ») pour les incidents de sécurité. En cas d'urgence, appeler d'abord, écrire ensuite.

DÉCLARANT _____

DATE ET HEURE DE DÉCOUVERTE _____

OUTIL OU APPAREIL CONCERNÉ _____

Nature : ☐ Message frauduleux ou lien cliqué ☐ Compte utilisé par un tiers ☐ Poste ou téléphone perdu ou volé ☐ Logiciel malveillant ☐ Demande de paiement frauduleuse ☐ Envoi d'informations à un mauvais destinataire ☐ Indisponibilité d'un service ☐ Autre

| | |
|---|---|
| **Ce qui s'est passé** | |
| **Informations ou clients concernés** | |
| **Ce que j'ai déjà fait** | |

TRAITEMENT

☐ Appareil isolé ☐ Mots de passe changés et sessions fermées ☐ Banques alertées ☐ Données restaurées ☐ Prestataire informé

Données personnelles touchées : ☐ Non ☐ Oui → décision du Directeur Général : ☐ clients informés ☐ autorité de protection des données informée ☐ COSUMAF informée

CAUSE ET MESURES POUR ÉVITER QU'IL SE REPRODUISE _____

CLOS LE · RÉFÉRENT INFORMATIQUE · RCCI _____

PROJET

ANNEXE « MESURES MINIMALES » · POLITIQUE DE SÉCURITÉ DES SYSTÈMES D'INFORMATION · TABLEAU DE RÉFÉRENCE

# Mesures minimales par outil

Version 0.9
Interne

**Renseigné par** Référent informatique, avec le prestataire **Fréquence** Revue annuelle et à chaque nouvel outil **Conservé par** RCCI · vérifié lors du contrôle annuel

La colonne « En place » est cochée lors de chaque vérification ; une mesure absente devient une action du plan de contrôle.

| Outil | Mesures minimales | Qui | Vérification | En place |
|---|---|---|---|---|
| Ordinateurs portables | Chiffrement du disque ; mises à jour automatiques ; antivirus actif ; verrouillage à 5 minutes ; pas de droits d'administration pour l'utilisateur ; effacement à distance possible | Prestataire | Semestrielle | ☐ |
| Téléphones professionnels | Code de verrouillage ; mises à jour ; effacement à distance ; applications professionnelles seulement pour les données de clients | Référent informatique | Semestrielle | ☐ |
| Messagerie et bureautique en ligne | Authentification à plusieurs facteurs pour tous ; paramètres de sécurité par défaut activés ; compte d'urgence sous scellé ; transfert automatique externe bloqué ; alertes de connexion ; SPF, DKIM et DMARC publiés | Prestataire, Directeur Général | Trimestrielle | ☐ |
| Guichet | Second facteur obligatoire au desk ; séparation proposition et approbation ; journal d'audit chaîné vérifié ; relecture avant fusion sur la branche de production ; secrets dans les variables protégées ; plafonds de dépense des API | Responsable du Guichet | Trimestrielle | ☐ |
| Base de données du Guichet | Accès console nominatif avec second facteur ; sauvegardes automatiques et copie externe ; clef de service jamais exposée côté client | Responsable du Guichet | Trimestrielle | ☐ |
| Site internet et nom de domaine | Second facteur chez l'hébergeur et le registraire ; verrou de transfert du domaine ; renouvellement automatique ; certificat HTTPS | Directeur Général | Annuelle | ☐ |
| Banque en ligne | Double signature des paiements ; jetons individuels ; plafonds ; alertes | Directeur Général | Semestrielle | ☐ |
| Coffre-fort de mots de passe | Second facteur ; partage par dossier selon le besoin ; accès de secours défini | Référent informatique | Semestrielle | ☐ |
| Sauvegardes | Trois copies, deux supports, une hors ligne ou chez un autre fournisseur ; restauration testée | Prestataire | Trimestrielle | ☐ |
| Réseau du bureau | Mot de passe Wi-Fi robuste ; réseau invités séparé ; équipement à jour ; double accès internet | Prestataire | Annuelle | ☐ |

VÉRIFIÉ LE _____ RÉFÉRENT INFORMATIQUE _____ RCCI _____

PROJET